

MODULE 1: What is Networking (Through a Security Lens)?

1. Networking as an Attack Surface (VAPT Perspective)

To a **Penetration Tester**, a network is:

- **A Battlefield of Trust Relationships:** Every connection, handshake, or authentication mechanism represents a *trust boundary*—and trust is what attackers exploit. Internal networks often assume implicit trust (e.g., flat networks, default VLANs), making lateral movement trivial once initial access is gained.
 - **A Roadmap of Exposed Assets:** Networks are *discoverable*. Open ports, misconfigured services, and default credentials are low-hanging fruit. A single exposed RDP port (TCP/3389) or SMB (TCP/445) can lead to domain compromise.
 - **A Collection of Misconfigurations Waiting to Be Abused:**
 - **IP Addressing:** Predictable or sequential IPs enable subnet scanning and host enumeration.
 - **Subnetting:** Poorly segmented networks allow attackers to pivot freely (e.g., no DMZ isolation).
 - **Routing:** Misconfigured routes (e.g., static routes pointing to untrusted networks) can redirect traffic to attacker-controlled systems.
 - **Switching:** Lack of port security (e.g., no MAC flooding protection) enables ARP spoofing and VLAN hopping.
 - **DNS:** Stale records, zone transfers, or recursive queries can leak internal hostnames and IPs.
 - **DHCP:** Rogue servers can hand out malicious gateways/DNS, redirecting traffic.
 - **NAT:** Misconfigured NAT rules can expose internal services to the internet (e.g., hairpin NAT leaks).
 - **A Playground for Protocol Abuse:** Every protocol has *design flaws* or *implementation weaknesses* that can be weaponized:
 - TCP's 3-way handshake can be abused for SYN floods (DoS) or session hijacking.
 - ICMP can be used for covert tunneling or network mapping.
 - DNS can exfiltrate data via tunneling or poison cache entries.
-

2. Networking as Telemetry (SOC Perspective)

To a **SOC Analyst**, a network is:

- **A Stream of Telemetry:** Every packet, log, and flow is a *signal*. The goal is to distinguish between:
 - **Baseline Noise:** Legitimate traffic (e.g., Windows updates, internal backups).
 - **Anomalous Signals:** Unusual protocols, unexpected ports, or traffic to known C2 IPs.
- **A Map of Chokepoints:** Critical control points where attacks *must* pass through:
 - **Firewalls/IDS/IPS:** Logs of blocked/dropped connections reveal probing attempts.
 - **Proxies:** HTTP/HTTPS logs show web-based attacks (e.g., SQLi, XSS, or C2 beacons).
 - **NetFlow/sFlow:** Aggregated traffic data reveals lateral movement or data exfiltration.
- **A Timeline of Events:** PCAPs and logs allow *reconstruction* of an attack:
 - **Initial Access:** External IP → Exposed service (e.g., RDP brute force).
 - **Lateral Movement:** Internal host → SMB/PSEXec to other subnets.
 - **Data Exfiltration:** Large outbound connections to external IPs (e.g., DNS tunneling, HTTPS to C2).
- **A System of Trust Validation:** SOCs verify that:
 - **Authentication** is not bypassed (e.g., Kerberos golden ticket detection).
 - **Encryption** is not subverted (e.g., TLS stripping, downgrade attacks).
 - **Segments** are not breached (e.g., East-West traffic between VLANs).

3. Core Components: Abuse Cases & Security Implications

Component	Normal Function	Abuse/Misconfiguration Impact	Security Risk
IP Addressing	Unique host identification	Predictable IPs → Easy scanning; IP spoofing → Bypasses ACLs	Host enumeration, session hijacking, DoS
Subnetting	Network segmentation	Flat networks → No isolation; Misconfigured VLANs → VLAN hopping	Lateral movement, broadcast storms
Routing	Traffic forwarding	Misconfigured static routes → Traffic redirection to attacker; BGP hijacking → MITM	Man-in-the-Middle, data interception
Switching	Layer 2 forwarding	No port security → MAC flooding; STP misconfig → MITM via ARP spoofing	ARP poisoning, VLAN hopping, MAC flooding DoS

DNS	Domain → IP resolution	Cache poisoning → Redirects to malicious IPs; Zone transfers → Internal recon	Phishing, C2 redirect, data exfiltration (DNS tunneling)
DHCP	Automatic IP assignment	Rogue DHCP → Malicious gateway/DNS; Starvation → DoS	MITM, traffic redirection, network disruption
NAT	IP translation (private ↔ public)	Misconfigured rules → Internal services exposed; Hairpin NAT → Internal IP leakage	Unauthorized access, data exposure

MODULE 2: Why Networking is the Absolute Foundation of VAPT and SOC

1. The VAPT Track: Why Networking Mastery is Non-Negotiable

A. Evading Network Defenses (IDS/IPS/Firewalls)

- **Understanding Detection Mechanisms:**
 - **Signature-Based IDS/IPS:** Bypassed via *protocol obfuscation* (e.g., HTTP tunneling, base64-encoded payloads) or *fragmentation* (IP/TCP segmentation to evade pattern matching).
 - **Anomaly-Based IDS/IPS:** Bypassed by *blending in* (e.g., using common ports like 443/80 for C2, or mimicking normal traffic rates).
 - **Firewalls:** Bypassed via:
 - **Port Hopping:** Using non-standard ports (e.g., C2 over TCP/53 or UDP/80).
 - **Protocol Tunneling:** Encapsulating malicious traffic in allowed protocols (e.g., DNS tunneling, ICMP exfiltration).
 - **Stateful Inspection Evasion:** Crafting packets to exploit firewall state tracking (e.g., TCP sequence number prediction, SYN floods to exhaust connection tables).
- **Practical Example:**
 - **Nmap Evasion:** Use -f (fragmented packets), --data-length 24 (pad packets), or --badsum (invalid checksums to bypass simple filters).
 - **Metasploit:** Use generic/allow_all_ports or http_tunnel modules to bypass restrictive egress rules.

B. Pivoting & Lateral Movement

- **Network Topology Awareness:**
 - **Subnet Mapping:** Use nmap -sn or arp-scan to identify live hosts in a subnet.

- **Routing Analysis:** traceroute or mtr to map internal network paths and identify pivot points (e.g., routers, proxies).
- **VLAN Hopping:** Exploit misconfigured trunk ports (802.1Q) to access other VLANs.
- **Pivoting Techniques:**
 - **Proxy Chaining:** Use compromised hosts as SOCKS/HTTP proxies (e.g., proxychains, ssh -D).
 - **Port Forwarding:** ssh -L or netsh portproxy to forward traffic through a compromised host.
 - **Tunneling:** plink, chisel, or ngrok to create encrypted tunnels out of restricted networks.
- **Lateral Movement Protocols:**

Protocol	Attack Vector	Tools/Commands
SMB	Pass-the-Hash, PSEXec	crackmapexec, impacket-psexec
RDP	Credential stuffing, RDP hijacking	xfreerdp, tscon (session hijacking)
SSH	Key-based auth bypass, SSH tunneling	ssh2john, ssh -R (reverse tunnel)
WinRM	PowerShell Remoting	evil-winrm, Invoke-Command
LDAP	Kerberos attacks (AS-REP roasting)	Impacket-GetNPUsers, Rubeus

C. Crafting Custom Payloads & Traffic Manipulation

- **Packet Crafting:**
 - **Scapy:** Python library to create custom packets (e.g., TCP SYN with spoofed IP, ICMP tunneling).
 - **Hping3:** Craft arbitrary TCP/IP packets for testing firewalls/IDS (e.g., hping3 -S -p 80 --flood for SYN flood).
- **Spoofing & Poisoning:**
 - **ARP Spoofing:** arpspoof or ettercap to redirect traffic (MITM).
 - **DNS Spoofing:** dnsspoof or Responder to poison DNS cache.
 - **IP Spoofing:** nmap -S <spoofed_IP> to bypass IP-based ACLs.
- **Protocol-Specific Attacks:**
 - **TCP:** SYN floods, RST injection, sequence number prediction.
 - **UDP:** Amplification attacks (e.g., DNS, NTP, SNMP).
 - **ICMP:** Tunneling (e.g., icmpsh), covert channels.

D. Interpreting Scan Results (Nmap/Masscan)

- **Avoiding Noise:**

- **Stealth Scanning:** -sS (SYN scan), -sT (TCP connect scan with slower timing).
 - **Timing Control:** --max-rate 50 (limit packets per second to avoid triggering rate-based alerts).
 - **Decoy Scanning:** -D RND:10 (hide your IP among random decoys).
 - **Advanced Interpretation:**
 - **Port States:**
 - open: Service is listening (potential attack vector).
 - filtered: Firewall/IDS may be blocking (try evasion techniques).
 - closed: Host is up but port is not listening (could indicate a filtered port).
 - **Service Fingerprinting:** Use -sV to identify service versions (e.g., Apache 2.4.49 → CVE-2021-41773).
 - **OS Detection:** -O to identify OS (helps in crafting targeted exploits).
-

2. The SOC Track: Why Networking Mastery is Non-Negotiable

A. Triage & Root Cause Analysis (RCA)

- **PCAP Analysis:**
 - **Tools:** Wireshark, TShark, NetworkMiner.
 - **Key Filters:**
 - tcp.stream eq X (follow a specific TCP stream).
 - ip.src == <suspicious_IP> or ip.dst == <suspicious_IP>.
 - dns.qry.type == TXT (DNS tunneling detection).
 - http.request.method == POST (look for data exfiltration).
 - **Attack Reconstruction:**
 1. **Initial Access:** External IP → Vulnerable service (e.g., ETW event 4625 for failed logins, then 4624 for success).
 2. **Lateral Movement:** Internal IPs communicating over SMB/RDP/WinRM.
 3. **C2 Beaconing:** Periodic HTTPS requests to unknown domains (check ja3 fingerprints).
 4. **Data Exfiltration:** Large outbound flows to external IPs (e.g., DNS or HTTPS with high byte counts).
- **Log Correlation:**
 - **SIEM Queries** (e.g., Splunk, ELK):

B. Distinguishing Noise from Signal

- **False Positives vs. True Positives:**

Indicator	Noise (Benign)	Signal (Malicious)
Port Scanning	Internal vulnerability scanners	External IPs scanning multiple ports
Failed Logins	User typos	Brute force (100+ failed attempts in 1 min)
Unusual Protocols	Legacy systems (e.g., NetBIOS)	ICMP tunneling, DNS TXT queries
High Bandwidth	Software updates	Data exfiltration to rare TLDs (e.g., .ru)
New Internal IPs	DHCP leases	Rogue devices (e.g., Raspberry Pi)

- **Baselining:**

- **Normal Traffic:** Document typical protocols, ports, and bandwidth usage per subnet.
- **Anomaly Detection:** Use ML (e.g., Splunk ML Toolkit) or threshold-based alerts (e.g., "Alert if >100 DNS TXT queries/hour").

C. Reading Firewall Rules, ACLs, and Routing Tables

- **Firewall Rule Analysis:**

- **Order Matters:** Rules are evaluated top-down. A DENY ALL at the top blocks everything; a PERMIT ALL at the bottom makes the firewall useless.
- **Implicit Trust:** Look for any rules or overly permissive PERMIT statements (e.g., PERMIT TCP ANY ANY 3389).
- **Shadowing:** A more specific DENY rule below a broad PERMIT is ineffective.
- **Tools:** iptables -L -n -v, nft list ruleset, or Cisco show access-lists.

- **ACLs (Access Control Lists):**

- **Standard ACLs:** Filter by source IP only (risk: spoofing).
- **Extended ACLs:** Filter by source/dest IP, port, protocol (better for granular control).
- **Named ACLs:** Easier to manage but often misconfigured.

- **Routing Tables:**

- **Static Routes:** Check for unexpected next hops (e.g., 0.0.0.0 0.0.0.0 <external_IP>).
- **BGP/OSPF:** Look for unauthorized route advertisements (e.g., BGP hijacking).
- **Tools:** route print (Windows), ip route (Linux), show ip route (Cisco).

- **Incident Containment:**

- **Step 1:** Identify the malicious flow (source/dest IP, port, protocol).
- **Step 2:** Block at the firewall:
- **Step 3:** Isolate the host (e.g., VLAN quarantine, disable switch port).
- **Step 4:** Preserve logs/PCAPs for forensics.

D. Sensor Placement for Maximum Visibility

- Strategic Locations for Taps/SPAN Ports:

Location	Visibility	Use Case
Internet Edge	North-South traffic	External attacks, C2 beaconing
DMZ	Public-facing services	Web app attacks, brute force
Internal Core	East-West traffic	Lateral movement, internal recon
Critical Servers	Database, DC, file shares	Data exfiltration, privilege escalation
Remote Access Points	VPN, RDP gateways	Credential stuffing, session hijacking

- SPAN vs. Tap:
 - **SPAN (Switch Port Analyzer):** Mirror traffic from a switch port. *Risk:* Can drop packets under high load.
 - **Tap (Network Tap):** Passive, no packet loss. *Best for:* High-traffic environments (e.g., 10Gbps+).
- NetFlow/sFlow:
 - **NetFlow:** Cisco’s flow data (source/dest IP, port, byte count). *Use for:* Traffic analysis, anomaly detection.
 - **sFlow:** Sampling-based (less accurate but scalable). *Use for:* Large networks where full PCAP is infeasible.

MODULE 3: Deep-Dive Blueprint – Core Network Protocols

1. TCP/UDP

A. Protocol Mechanics

Aspect	TCP	UDP
Connection	Connection-oriented (3-way handshake)	Connectionless (no handshake)
Reliability	Guaranteed delivery (ACKs, retries)	Best-effort (no retries)
Ordering	In-order delivery (sequence numbers)	No ordering
Flow Control	Window scaling, congestion control	None
Overhead	Higher (headers + ACKs)	Lower (minimal header)
Use Cases	HTTP, FTP, SSH, SMTP	DNS, DHCP, VoIP, QUIC (HTTP/3)

- TCP 3-Way Handshake:
 1. **SYN:** Client → Server (ISN = X).

2. **SYN-ACK:** Server → Client (ISN = Y, ACK = X+1).
3. **ACK:** Client → Server (ACK = Y+1).
 - *Vulnerability:* SYN floods (attacker sends SYN but never ACKs, exhausting server's half-open connections).

B. VAPT Exploitation

Attack	Mechanism	Tools/Commands
SYN Flood (DoS)	Send SYN packets with spoofed IPs; server waits for ACK, exhausting resources.	hping3 -S --flood -p 80
TCP Connect Scanning	Full 3-way handshake to check if port is open (noisy but reliable).	nmap -sT
TCP SYN Scanning	Send SYN, wait for SYN-ACK (stealthier; no full connection).	nmap -sS
TCP RST Injection	Inject RST packets to tear down established connections (DoS or session hijacking).	scapy: send(IP(dst="X")/TCP(sport=Y,dport=Z,flags="R")/Raw("X"))
TCP Sequence Prediction	Guess TCP sequence numbers to spoof a trusted host's connection.	scapy (manual crafting)
UDP Flood	Send high-volume UDP packets to overwhelm a service (e.g., DNS, VoIP).	hping3 --udp --flood -p 53
UDP Amplification	Spoof source IP, send small UDP request to amplifier (e.g., DNS, NTP), which replies with large response to victim.	dnscat2, custom scripts

C. SOC Detection

Attack	Detection Method	Tools/Queries
SYN Flood	High rate of SYN packets with no ACK; many half-open connections.	Wireshark: tcp.flags.syn == 1 && tcp.flags.ack == 0
TCP Port Scanning	Multiple SYN packets to different ports from a single IP.	` Zeek: conn.log
UDP Flood	High volume of UDP packets to a single port from multiple IPs.	` Splunk: index=netflow src_port=53 dest_ip=
TCP RST Injection	Unexpected RST packets in established connections.	Wireshark: tcp.flags.reset == 1
UDP Amplification	Large UDP responses from amplifiers to a victim IP (spoofed source).	NetFlow: Look for asymmetric traffic (small in, large out)

D. Defensive Fixes/Mitigations

Attack	Mitigation
SYN Flood	Enable SYN cookies (Linux: net.ipv4.tcp_syncookies=1), rate limiting, or use a WAF.
TCP Port Scanning	Rate limit SYN packets per IP; deploy IDS/IPS with scan detection rules.
UDP Flood	Rate limiting at firewall; disable unused UDP services.
UDP Amplification	Disable open UDP amplifiers (e.g., DNS, NTP, SNMP) on public IPs.
TCP Sequence Prediction	Use random sequence numbers (modern OSes do this by default).

2. DNS

A. Protocol Mechanics

- **DNS Resolution Process:**
 1. **Local Cache Check:** OS checks its DNS cache.
 2. **Recursive Resolver Query:** If not cached, query the configured DNS server (e.g., 8.8.8.8).
 3. **Root → TLD → Authoritative Server:** Resolver queries root (.) → TLD (.com) → authoritative server (example.com).
- **Record Types:**
 - **A:** IPv4 address.
 - **AAAA:** IPv6 address.

- **MX:** Mail server.
- **CNAME:** Alias for another domain.
- **TXT:** Arbitrary text (used for SPF, DKIM, or exfiltration).
- **NS:** Name server for the domain.

B. VAPT Exploitation

Attack	Mechanism	Tools/Commands
DNS Tunneling	Encode data in DNS queries/responses (e.g., base32 in TXT records).	dnscat2, iodine, Heyoka
DNS Cache Poisoning	Spoof DNS responses to redirect traffic to malicious IPs.	ettercap, dnsspoof
Domain Generation Algorithms (DGA)	Malware generates random domains to evade blacklisting (e.g., abc123.baddomain.com).	fgdump, custom Python scripts
DNS Zone Transfer	Exploit misconfigured DNS servers to dump all records for a domain.	dig axfr @
DNS Rebinding	Rapidly change DNS A records to bypass same-origin policy (e.g., for SSRF).	Custom DNS server (e.g., dnsmasq)
Subdomain Brute Force	Discover hidden subdomains (e.g., dev.example.com, admin.example.com).	dnsrecon, amass, subfinder

C. SOC Detection

Attack	Detection Method	Tools/Queries
DNS Tunneling	Unusually long TXT queries; high volume of DNS queries to a single domain.	Wireshark: dns.qry.type == 16 (TXT)
DNS Cache Poisoning	Sudden redirection of a domain to an unknown IP; multiple A records for a domain.	`Zeek: dns.log
DGA Domains	Domains with random strings (e.g., abc123.baddomain.com); low reputation scores.	VirusTotal, `Splunk: index=dns
DNS Zone Transfer	AXFR requests (rare in normal traffic).	Wireshark: dns.flags.response == 0 && dns.opcode == 5
DNS Rebinding	Rapid DNS A record changes for the same domain.	PassiveDNS, `Splunk: index=dns domain=

D. Defensive Fixes/Mitigations

Attack	Mitigation
DNS Tunneling	Block outbound DNS to non-corporate servers; inspect DNS TXT queries.

DNS Cache Poisoning	Use DNSSEC; restrict recursive queries to trusted sources.
DGA Domains	Deploy DNS filtering (e.g., Cisco Umbrella, OpenDNS); use ML-based detection.
DNS Zone Transfer	Disable AXFR on public DNS servers; restrict to authorized IPs.
DNS Rebinding	Monitor for rapid DNS changes; block known malicious domains.

3. ARP & DHCP

A. Protocol Mechanics

- **ARP (Address Resolution Protocol):**
 - **Purpose:** Map IP addresses to MAC addresses (Layer 2).
 - **Process:**
 1. **ARP Request:** "Who has IP X? Tell Y" (broadcast).
 2. **ARP Reply:** "IP X is at MAC Z" (unicast to Y).
 - **Gratuitous ARP:** Unsolicited ARP reply to update cache (used in ARP spoofing).
- **DHCP (Dynamic Host Configuration Protocol):**
 - **Purpose:** Automatically assign IP addresses, gateways, DNS servers.
 - **Process (DORA):**
 1. **Discover:** Client broadcasts DHCPDISCOVER.
 2. **Offer:** Server replies with DHCPOFFER (IP, gateway, DNS).
 3. **Request:** Client requests the offered IP (DHCPREQUEST).
 4. **Ack:** Server confirms (DHCPACK).

B. VAPT Exploitation

Attack	Mechanism	Tools/Commands
ARP Spoofing (MITM)	Send gratuitous ARP replies to redirect traffic through attacker's MAC.	arp spoof -i eth0 -t
ARP Poisoning	Corrupt ARP cache to associate a malicious MAC with a legitimate IP.	ettercap -T -i eth0 -M arp:remote // //
DHCP Starvation	Flood DHCP server with fake requests to exhaust IP pool.	isc-dhcp-server (malicious config), Yersinia

Rogue DHCP Server	Set up a fake DHCP server to hand out malicious gateway/DNS.	dhcpcd (malicious config), metasploit: auxiliary/spoof/dhcp/dhcpcd
VLAN Hopping	Exploit misconfigured trunk ports to access other VLANs (802.1Q).	Yersinia, scapy (craft 802.1Q frames)

C. SOC Detection

Attack	Detection Method	Tools/Queries
ARP Spoofing	Multiple ARP replies for the same IP; MAC address flapping.	Wireshark: arp.opcode == 2 (Reply) && eth.src !=
DHCP Starvation	Sudden spike in DHCP requests; IP pool exhaustion alerts.	` Splunk: index=dhcp event="DHCPDISCOVER"
Rogue DHCP Server	Unexpected DHCPACK messages from unauthorized IPs.	Wireshark: dhcp && ip.src !=
VLAN Hopping	802.1Q frames with unexpected VLAN tags; traffic from a host in VLAN A to VLAN B.	Wireshark: vlan && eth.src !=

D. Defensive Fixes/Mitigations

Attack	Mitigation
ARP Spoofing	Enable ARP inspection (dynamic ARP inspection on Cisco switches).
DHCP Starvation	Implement DHCP snooping (validate DHCP requests); use port security.
Rogue DHCP Server	Use DHCP snooping to block unauthorized servers; monitor for rogue DHCP.
VLAN Hopping	Disable auto-trunking ; use switchport mode access on end-user ports.

4. ICMP

A. Protocol Mechanics

- **Purpose:** Network diagnostics (e.g., ping, traceroute).
- **Message Types:**
 - **Echo Request (Type 8):** ping request.
 - **Echo Reply (Type 0):** ping response.
 - **Destination Unreachable (Type 3):** Host/network unreachable.
 - **Redirect (Type 5):** Router suggests a better path.
 - **Time Exceeded (Type 11):** TTL expired (used by traceroute).

B. VAPT Exploitation

Attack	Mechanism	Tools/Commands
ICMP Tunneling	Encode data in ICMP echo requests/responses (e.g., ping -p).	icmpsh, ptunnel
ICMP Flood (Ping Flood)	Send high-volume ICMP echo requests to overwhelm a target.	hping3 --icmp --flood
ICMP Redirect	Spoof ICMP redirect messages to manipulate routing tables.	scapy: send(IP(dst="X")/ICMP(type=5, code=1, gw="Y")/IP(src="Z", dst="W"))
Network Discovery	Use ping sweeps to identify live hosts in a subnet.	nmap -sn , fping -a -g
OS Fingerprinting	Analyze ICMP responses (TTL, window size) to guess OS.	nmap -O

C. SOC Detection

Attack	Detection Method	Tools/Queries
ICMP Tunneling	Unusually large ICMP packets; non-standard ICMP types/codes.	Wireshark: icmp && frame.len > 100
ICMP Flood	High rate of ICMP echo requests from a single IP.	` Splunk: index=netflow icmp_type=8
ICMP Redirect	Unexpected ICMP type 5 messages.	Wireshark: icmp.type == 5
Ping Sweep	Multiple ICMP echo requests to sequential IPs in a subnet.	` Zeek: conn.log

D. Defensive Fixes/Mitigations

Attack	Mitigation
ICMP Tunneling	Block ICMP at the firewall (or allow only echo request/reply).
ICMP Flood	Rate limit ICMP traffic; use iptables -A INPUT -p icmp --icmp-type echo-request -m limit --limit 1/s -j ACCEPT.
ICMP Redirect	Disable ICMP redirects on hosts (net.ipv4.conf.all.accept_redirects=0).
Ping Sweep	Monitor for rapid ICMP scans; deploy IDS rules to alert on sweeps.

5. HTTP/HTTPS & TLS

A. Protocol Mechanics

- **HTTP/HTTPS:**

- **HTTP:** Plaintext (port 80); stateless (cookies/sessions for state).
- **HTTPS:** HTTP over TLS (port 443); encrypted.

- **TLS Handshake:**

1. **Client Hello:** Client sends supported cipher suites, TLS version.
2. **Server Hello:** Server selects cipher suite, sends certificate.
3. **Key Exchange:** Client and server exchange keys (e.g., RSA, ECDHE).
4. **Session Establishment:** Symmetric key used for encryption.

B. VAPT Exploitation

Attack	Mechanism	Tools/Commands
SSL/TLS Stripping	Downgrade HTTPS → HTTP to capture credentials in plaintext.	sslstrip, mitmproxy
Heartbleed (CVE-2014-0160)	Exploit OpenSSL heartbeat extension to leak memory.	metasploit: auxiliary/scanner/ssl/openssl_heartbleed
POODLE (CVE-2014-3566)	Exploit SSL 3.0 padding oracle to decrypt traffic.	testssl.sh, poodle-exploit
BEAST (CVE-2011-3389)	Exploit CBC mode in TLS 1.0 to decrypt cookies.	beast.py (custom script)
Certificate Spoofing	Use self-signed or expired certificates to impersonate a site.	openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365 -nodes
HTTP Request Smuggling	Exploit discrepancies in front-end/back-end parsing to poison caches or bypass security.	Burp Suite, smuggler.py
Web Application Attacks	Exploit vulnerabilities in web apps (SQLi, XSS, RCE).	sqlmap, Burp Suite, OWASP ZAP

C. SOC Detection

Attack	Detection Method	Tools/Queries
TLS Stripping	HTTP traffic to/from HTTPS ports; missing Upgrade: HTTPS headers.	Wireshark: http && tcp.port == 443
Heartbleed	TLS heartbeat requests/responses with unusual payloads.	Wireshark: tls.handshake.type == 24 (Heartbeat)

Certificate Anomalies	Self-signed certs, expired certs, or mismatched CN/SAN.	`Zeek: x509.log
HTTP Request Smuggling	Discrepancies in Content-Length vs. Transfer-Encoding headers.	Burp Suite Scanner, Wireshark: http.content_length != http.file_data.length
Web Application Attacks	SQLi patterns (' OR 1=1 --), XSS payloads (	

D. Defensive Fixes/Mitigations

Attack	Mitigation
TLS Stripping	Enforce HSTS (Strict-Transport-Security header); block HTTP on port 80.
Heartbleed/POODLE	Patch OpenSSL; disable vulnerable TLS versions (use TLS 1.2+).
Certificate Spoofing	Use certificate pinning; monitor for unauthorized certs (e.g., CertSpotter).
HTTP Request Smuggling	Normalize headers; use a single reverse proxy (avoid dual-stack setups).
Web Application Attacks	Deploy WAF (e.g., ModSecurity, Cloudflare); input validation.

Final Notes: The Path to Mastery

1. Hands-On Practice:

- **VAPT:** Set up a lab with Metasploitable, Kali Linux, and Wireshark. Practice scanning, exploiting, and evading defenses.
- **SOC:** Use tools like Security Onion, ELK, or Splunk to analyze PCAPs and logs. Simulate attacks and practice detection.

2. Resources:

- **Tools:** Wireshark, TShark, Zeek, Suricata, Nmap, Metasploit, Burp Suite.

3. Mindset:

- **VAPT:** Think like an attacker—*how can I break this?*
- **SOC:** Think like a detective—*what's out of place?*